TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

CISA confirms active exploitation of WordPress Core upgrade-window RCE

From **Cybersecurity Briefing** · Covering 2026-10-30 to 2026-11-04 (US, Global, Industry and patches: last 24 hours, with the hard cutoff at 2026-10-30; Indianapolis and Indiana: five days) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-04	1.0 · 2026-11-04 10:38 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-03	2026-11-04
CVES	**ANALYST**	
CVE-2026-119977 (CVSS 8.1)	Nick Sturgeon	

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CISA added CVE-2026-119977, a time-of-check to time-of-use race condition (CWE-367) in WordPress Core, to its Known Exploited Vulnerabilities catalog on 2026-11-03 with a federal due date of 2026-11-06 [S4] [S5]. During a full-package core update, affected versions unpack the new release into a predictable folder under the web-served wp-content/upgrade directory, and that copy includes the installer, setup-config.php. An unauthenticated attacker who requests the staged installer in the seconds before cleanup can reach PHP code execution [S3] [S6] [S8] [S9]. All branches from 4.7.0 through 7.1.3 are affected. The fix shipped on 2026-10-28 in 7.1.4, with backports to every branch down to 4.7.39, so 7.1.4 is not the only fixed release [S2] [S6].

Attackers moved quickly. Wordfence, as relayed by the press, logged a first matching request about nine minutes after its firewall rule went live on 2026-10-28, more than 18,500 requests against staged setup-config.php paths in the first 21 hours, and two sources that polled small groups of sites for about 14.5 hours, apparently waiting for an update to start [S1] [S8] [S14]. Recent daily counts are about 12,000 blocked attempts [S1] [S10]. Previdian separately recorded three attempts from one UK-geolocated address on one sensor on 2026-10-30 [S7]. These figures measure attempts. We found no public report of a confirmed successful compromise, no attacker IP list, no user agents and no malware hashes [S10] [S15] [S16]. CISA cites evidence of active exploitation but has not published that evidence [S5].

Severity is genuinely contested. Wordfence, the CVE assigner, scores the flaw CVSS 8.1 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H), while the WordPress advisory rates it Low [S3] [S6]. The two views fit together: impact is total when the race is won, but winning is hard, and it also requires a full-

package update, web and PHP access to the staging tree, and a known or guessable path [S8]. EPSS is low at 0.0102 [S19]. We assess the per-site risk as moderate and short-lived, but it is concentrated at the worst moment, because the act of updating opens the window. KEV listing and active polling justify urgent action regardless of the vendor's rating.

Defenders should block web access to /wp-content/upgrade/ at the web server, CDN or WAF first, then update to the fixed release for the branch, and keep that block in place permanently [S9] [S10]. Preserve logs and review them from 2026-10-28 onward, with extra attention to each site's update time. A POST returning 200 to a staged installer should be handled as a probable compromise [S10]. CISA's forensic triage steps are binding only on federal civilian agencies, but they are a sound template for everyone else [S4] [S5] [S13]. PHP-level firewall plugins may not see these requests at all, because the staged copy loads from its own files [S9] [S10].

Key judgments

> **VERY LIKELY · MODERATE CONFIDENCE**
> Automated polling of staged installer paths will very likely continue at thousands of blocked requests per day across the Wordfence network through at least the end of November 2026, since an unpatched site stays worth watching until it next updates, even as counts have fallen from their late-October peak. [S1] [S8] [S10]

> **UNLIKELY · MODERATE CONFIDENCE**
> This flaw is unlikely to produce a mass-compromise event in the next 30 days, because the window lasts seconds, several server conditions must line up, and no public reporting shows successful compromises. Individual compromises are still plausible, particularly on sites with slow updates or directory listing enabled. [S3] [S8] [S9] [S15] [S19]

> **ROUGHLY EVEN CHANCE · LOW CONFIDENCE**
> There is a roughly even chance that a security vendor or government agency publishes a confirmed compromise case or attacker-specific indicators within 30 days. CISA's listing implies evidence not yet public, and vendors hold unpublished telemetry, but successful exploitation may leave little trace other than short-lived web log entries. [S5] [S7] [S10]

> **ALMOST CERTAIN · MODERATE CONFIDENCE**
> A meaningful population of self-managed sites, including sites with automatic updates disabled or sites on 4.6 and earlier, will almost certainly remain unpatched when WordPress 7.2 ships (planned for 2026-12-08), which would give attackers another broad update event to watch. [S2] [S15] [S17]

INDICATORS OF COMPROMISE

No source publishes attacker IP addresses, domains, user agents, webshell names or hashes; Previdian restricts its IP and path data to paid tiers [S7] and other reporting confirms the absence [S10] [S15] [S16]. Everything below is a behavioral or path-based hunting indicator from reporting current to 2026-11-04, plus a few clearly marked derived items. Many matches will be failed attempts, so a match is not proof of compromise.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/wp-content/upgrade/`	Web-served staging directory used during core updates. Any request to PHP beneath it should be reviewed. A request for the bare folder may mean the attacker read the staging folder name from a directory listing.	REPORTED	2026-10-28	[S8] [S9] [S10]
filename	`setup-config.php`	WordPress installer. The staged copy under wp-content/upgrade is the reported attack target. Over 18,500 requests aimed at these staged paths in the first 21 hours.	REPORTED	2026-10-28	[S1] [S8] [S9] [S14]
http-request	`(GET|POST) /wp-content/upgrade/[^ ]*\.php`	Published regex pattern for raw nginx or Apache logs. Matches any PHP request under the staging tree.	REPORTED	2026-10-28	[S10]
http-request	`POST /wp-content/upgrade/*setup-config.php returning HTTP 200`	ThreatDefence advises treating a POST with a 200 response to a staged installer as probable compromise. A 200 on any PHP file under the upgrade path is a priority.	REPORTED		[S10]
filename	`install.php`	Requests to install.php outside the normal /wp-admin/ location, especially POSTs, are a named hunting lead.	REPORTED		[S10]
other	`Single source repeating a few staged paths on a small group of sites for hours`	Wordfence saw two large sources polling this way for about 14.5 hours, consistent with waiting for an update window. Treat it as more serious than scanning.	REPORTED	2026-10-28	[S8] [S10] [S14]
other	`Single source cycling many staging-folder and version-name variations`	Wordfence reported probing of many path variants. ThreatDefence assesses this pattern as more likely a scanner than a targeted attempt.	REPORTED	2026-10-28	[S8] [S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`wp-content/upgrade/*` (anything other than `index.php` outside a running update)	Between updates the directory should hold only index.php on fixed versions. Leftover content deserves review.	REPORTED		[S9] [S10]
filepath	`wp-content/uploads/*.php`	New PHP files in the uploads tree are a named post-exploitation check.	REPORTED		[S10]
filepath	`wp-content/mu-plugins/*.php`	New or changed must-use plugins are a named post-exploitation check.	REPORTED		[S10]
filename	`wp-config.php`	Unexpected modification is a named check. The patch also stops this file being copied out of the working directory during an update [S9].	REPORTED		[S9] [S10]
filename	`.htaccess`	Unexpected changes are a named post-exploitation check.	REPORTED		[S10]
command	`php-fpm` or Apache parent spawning `sh`, `bash`, `curl`, `wget` or similar	Behavioral host indicator from hunting guidance, not an observed attacker command. The PHP mail() function spawns sendmail through a shell, so filter that out.	REPORTED		[S10] [S16]
other	Unfamiliar WordPress administrator accounts, plugins or themes; failed core checksum verification	Application-level signs of compromise named in reporting.	REPORTED		[S8] [S10] [S16]
http-request	`/wp-admin/update-core.php?action=do-core-upgrade`	Benign pivot rather than an attack indicator. Use it, wp-cron.php requests or the modification time of wp-includes/version.php to find each site's update time, then review requests from 5 minutes before to 10 minutes after.	REPORTED		[S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/wp-content/upgrade/<staging-folder>/.../wp-admin/setup-config.php`	Patchstack says the extracted package contains wp-admin/setup-config.php under the upgrade folder, so the staged path must include these segments. Exact pre-fix folder names are not published. Note that this path contains wp-admin, so log filters that simply exclude wp-admin would miss it; anchor any exclusion to the start of the path.	DERIVED		[S9]
port	`3306/tcp`	Patchstack describes the staged installer as a way to point WordPress at an attacker-controlled database. An outbound MySQL connection from a web server to an unknown external host around an update time would fit this. Port 3306 is an assumption based on the MySQL default, since attackers can choose another port.	DERIVED		[S9]
other	`DB_HOST in wp-config.php pointing to an unknown external host`	Inferred from the same installer mechanism and from the fix that blocks unsafe promotion of staged configuration data. No source reports this finding in a real intrusion. Easy to check and worth doing on recently updated sites.	DERIVED		[S9] [S14]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker does not need an account or any user action. They guess or discover the staging folder under wp-content/upgrade, either through its predictable name or through a directory listing exposed after cleanup removed index.php, and then repeatedly request the staged setup-config.php until an update happens to be running. Reporting indicates the staged installer runs without the site's configuration, which can let an attacker point it at a database they control and progress to PHP execution. The window normally lasts seconds in lab tests [S8] [S9] [S15]. Because the staged copy loads from its own files, a PHP firewall plugin running inside the site may never see the request [S9] [S10]. The fix appends 16 random characters to the folder name, retains index.php, and stops wp-config.php being copied out of the working directory [S9] [S14]. Reconnaissance and initial access are observed as attempts. All post-exploitation entries below are expected behavior drawn from hunting guidance, since no public case documents what attackers did after succeeding.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Sustained polling of staged setup-config.php paths on small groups of sites for about 14.5 hours, apparently to catch an update in progress. [S8] [S10] [S14]	Group web logs by source IP. Few distinct paths, many hits and many active hours indicate polling.
Reconnaissance	T1595.003 Active Scanning: Wordlist Scanning	Sources tested many staging-directory and version-name variations under wp-content/upgrade. [S8] [S10]	Group by source IP and alert on many distinct paths beneath /wp-content/upgrade/, including mostly 404 responses.
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated request to the staged installer during the race window of a full-package core update, leading to PHP code execution. [S3] [S6] [S8] [S9]	Requests to PHP under /wp-content/upgrade/, especially a POST returning 200, close to the site's update time.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Expected, not publicly observed: PHP or web server processes starting a shell or download tools. [S10] [S16]	EDR or auditd alerts on php-fpm or Apache spawning sh, bash, curl or wget, excluding sendmail invoked through mail().
Persistence	T1505.003 Server Software Component: Web Shell	Expected, not publicly observed: PHP files dropped in upgrade, uploads or must-use plugin folders, or malicious plugins. [S10] [S16]	File integrity monitoring on those folders; wp core checksum verification; review of plugin lists.
Persistence	T1136 Create Account	Expected, not publicly observed: creation of unfamiliar WordPress administrator accounts. [S8] [S10] [S16]	Compare the administrator list with a known-good record and review new-user activity since 2026-10-28.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Expected, not publicly observed: code running as the web user could read database credentials and salts from wp-config.php, plus other credentials reachable by PHP. [S10] [S16]	Rotate credentials after a suspected compromise and review database logins from unusual sources.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

PHP requests under the WordPress upgrade staging path `SIGMA`

```
title: Web Request To PHP Under WordPress Upgrade Staging Path
status: experimental
description: Requests to PHP files under wp-content/upgrade, associated with CVE-2026-119977 attempts
logsource:
  category: webserver
detection:
  selection:
    cs-uri-stem|contains: '/wp-content/upgrade/'
    cs-uri-stem|endswith: '.php'
  condition: selection
fields:
  - c-ip
  - cs-method
  - cs-uri-stem
  - sc-status
falsepositives:
  - Vulnerability scanners run by your own team
level: high
```

Triage POST with 200 first. Most hits should be failed attempts (404). Legitimate traffic to PHP on this path is not expected, since WordPress uses the folder through the filesystem [S10].

Separate pollers from scanners `SPLUNK SPL`

```
index=web uri_path="*/wp-content/upgrade/*" earliest="10/28/2026:00:00:00"
| bin _time span=1h as hour
| stats count AS hits dc(uri_path) AS distinct_paths dc(hour) AS active_hours values(status) AS
statuses min(_time) AS first_seen max(_time) AS last_seen BY src_ip, site
| eval pattern=case(distinct_paths<=5 AND active_hours>=4, "possible poller", distinct_paths>20,
"likely scanner", true(), "review")
| sort - active_hours
| convert ctime(first_seen) ctime(last_seen)
```

Adjust the index and field names. The thresholds are starting values, based on the polling behavior reported by Wordfence [S8] and ThreatDefence's distinction between the two patterns [S10].

Web server process spawning shell or download tools `KQL`

```
DeviceProcessEvents
| where Timestamp >= datetime(2026-10-28)
| where InitiatingProcessFileName startswith "php" or InitiatingProcessFileName in~ ("apache2",
"httpd")
| where FileName in~ ("sh", "bash", "dash", "curl", "wget", "nc", "python", "python3", "perl")
| where ProcessCommandLine !has "sendmail"
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName
| order by Timestamp desc
```

Microsoft Defender for Endpoint on Linux web hosts. Not specific to this CVE. Expect to tune out legitimate cron or deployment tasks. Most small WordPress hosting has no EDR, so use auditd where possible.

Network detection of PHP requests to the staging tree `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"LOCAL WordPress upgrade staging path PHP request (CVE-2026-119977 hunting)"; flow:established,to_server; http.uri; content:"/wp-content/upgrade/"; nocase; content:".php"; nocase; distance:0; classtype:web-application-attack; sid:1000001; rev:1;)
```

Sees only unencrypted traffic or traffic after TLS termination. Change the sid to fit your local range.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
WordPress Core 7.1	7.1.0 - 7.1.3	7.1.4	CVE-2026-119977	8.1 (Wordfence CNA); vendor rating Low	0.0102 (63.5th percentile, 2026-11-04)	Yes (added 2026-11-03)	2026-11-06
WordPress Core 7.0	7.0.0 - 7.0.7	7.0.8	CVE-2026-119977	8.1 (Wordfence CNA); vendor rating Low	0.0102 (63.5th percentile, 2026-11-04)	Yes (added 2026-11-03)	2026-11-06
WordPress Core 6.x	6.9.0-6.9.10, 6.8.0-6.8.11, 6.7.0-6.7.10, 6.6.0-6.6.10, 6.5.0-6.5.13, 6.4.0-6.4.13, 6.3.0-6.3.13, 6.2.0-6.2.14, 6.1.0-6.1.15, 6.0.0-6.0.17	6.9.11, 6.8.12, 6.7.11, 6.6.11, 6.5.14, 6.4.14, 6.3.14, 6.2.15, 6.1.16, 6.0.18	CVE-2026-119977	8.1 (Wordfence CNA); vendor rating Low	0.0102 (63.5th percentile, 2026-11-04)	Yes (added 2026-11-03)	2026-11-06
WordPress Core 5.x	5.9.0-5.9.19, 5.8.0-5.8.18, 5.7.0-5.7.20, 5.6.0-5.6.22, 5.5.0-5.5.23, 5.4.0-5.4.24, 5.3.0-5.3.26, 5.2.0-5.2.29, 5.1.0-5.1.27, 5.0.0-5.0.30	5.9.20, 5.8.19, 5.7.21, 5.6.23, 5.5.24, 5.4.25, 5.3.27, 5.2.30, 5.1.28, 5.0.31	CVE-2026-119977	8.1 (Wordfence CNA); vendor rating Low	0.0102 (63.5th percentile, 2026-11-04)	Yes (added 2026-11-03)	2026-11-06

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
WordPress Core 4.7 - 4.9	4.9.0-4.9.34, 4.8.0-4.8.33, 4.7.0-4.7.38	4.9.35, 4.8.34, 4.7.39	CVE-2026-119977	8.1 (Wordfence CNA); vendor rating Low	0.0102 (63.5th percentile, 2026-11-04)	Yes (added 2026-11-03)	2026-11-06
WordPress Core 4.6 and earlier	Outside the listed range. Do not assume safe: Patchstack dates the underlying sink to WordPress 2.8	No fix available; upgrade to a fixed branch	Not listed under CVE-2026-119977	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Build a list of every WordPress site you own or manage, including staging, development and agency-run sites, with version and whether updates are automatic. `IT OPS` [S15] [S16]
- Copy web server, CDN and WAF logs to safe storage from 2026-10-28 onward, before patching or log rotation can destroy them. Preserve evidence ahead of changes where practical on any site you suspect. `SOC` [S10] [S13]
- Deny web access to /wp-content/upgrade/ at the web server, CDN or WAF before starting the update, because the update itself opens the race window. Confirm a 403 response with no folder listing. WordPress uses this folder through the filesystem, so the block should not break updates. `IT OPS` [S9] [S10]
- Update each site to the fixed release for its branch, or to 7.1.4 where possible, then verify the running version. Do not assume automatic updates completed. `IT OPS` [S2] [S6] [S16]
- Search logs for PHP requests under /wp-content/upgrade/ and escalate any POST returning 200 as a probable compromise. `SOC` [S8] [S10]

Short term (1–7 days)

- For each site, find its update time from wp-includes/version.php, wp-cron.php requests or update-core.php requests, and review all requests from 5 minutes before to 10 minutes after. `SOC` [S10]
- Review sites updated since 2026-10-28 for unfamiliar administrator accounts, plugins, themes and PHP files in upgrade, uploads and mu-plugins; check for changes to wp-config.php and .htaccess; and run core checksum verification. `SOC` [S8] [S10] [S16]
- If compromise is suspected: isolate the site, preserve files, database and logs, scope what the web user could reach, rebuild from known-good copies, reinstall plugins and themes from official sources, and rotate

database credentials, wp-config.php salts, admin passwords, and API and hosting credentials. SOC [S10] [S13] [S16]

- Use the BOD 26-04 triage order as the template for suspected cases: scope, preserve evidence, patch, contain, analyze, then decide on escalation. Federal civilian agencies must meet the directive; for others it is a guide. SOC [S5] [S13]
- Ask each hosting provider in writing what it blocks and which WordPress versions it manages. Provider rules reduce risk but do not replace the update, and self-managed VPS or server sites stay your responsibility. IT OPS [S10] [S17] [S18]
- If Wordfence is deployed, enable Extended Protection so its firewall loads before WordPress, and note that free-tier sites do not receive the rule until 2026-11-27. Add a web server block on those sites. IT OPS [S10] [S14] [S15]
- Scan for this flaw with vendor checks where available, such as Qualys QID 735969, and enable Trend Micro's rules if licensed. SOC [S11] [S12]

Long term

- Keep the web server deny rule for /wp-content/upgrade/ permanently and add it to standard WordPress build templates. Update windows recur with every update, including unattended ones. IT OPS [S9]
- Disable directory listing across WordPress hosting, and deny PHP execution in upgrade and uploads folders at the web server. IT OPS [S9] [S10]
- Retire or migrate sites on WordPress 4.6 and earlier, and move sites on old branches to a current supported release. The project actively supports only the newest version. LEADERSHIP [S2] [S15]
- Assign a named owner for every WordPress site, including those run by marketing teams and outside agencies, and write update and log-retention duties into contracts. LEADERSHIP [S15] [S16]
- Retain web logs for at least 90 days and forward them centrally so that short-lived attack windows can be reviewed later. This retention period is our recommendation, not a source requirement. LEADERSHIP [S10]

Workarounds & compensating controls

- If a site cannot be updated right away, block /wp-content/upgrade/ at the web server, CDN or WAF and hold off on manual full-package updates until the block is confirmed. IT OPS [S9] [S10]
- Do not rely on a PHP firewall plugin alone. Enforce the control at the web server or edge, where it applies before the staged copy runs. IT OPS [S9] [S10]
- Restrict outbound traffic from web servers so they can reach only approved database hosts and required services. This limits a staged installer's ability to reach an attacker's database and limits download tools. Derived from the reported mechanism. IT OPS [S9]
- Use network and endpoint vendor signatures where licensed, such as Trend Micro IPS rule 1012774, TippingPoint filter 48746 and NDR rule 6045, as added coverage only. SOC [S12]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: CISA Confirms Hackers Exploiting WordPress Core Flaw During Software Upgrades
Published 2026-11-04 · **B2** Usually reliable, probably true
Briefing source. Relays Wordfence and Previdian telemetry.

[S2] WordPress.org: WordPress 7.1.4
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Primary vendor release post, cited in the KEV notes.

[S3] CVE Program: CVE-2026-119977 record
Published 2026-10-31 · **A1** Completely reliable, confirmed by other sources
Primary record, Wordfence as CNA; last updated 2026-11-04. Includes CISA SSVC data.

[S4] CISA: Known Exploited Vulnerabilities catalog (JSON feed, version 2026.11.03)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary source for KEV date, due date and required action.

[S5] CISA: CISA Adds One Known Exploited Vulnerability to Catalog
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary government alert. Does not detail the underlying evidence.

[S6] WordPress (GitHub): GHSA-4w3m-c66w-69mg: A race condition during core updates that could lead to remote code execution
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory with the branch table. Rates severity Low and listed no CVE when read.

[S7] Previdian: CVE-2026-119977 telemetry
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Single sensor, three attempts. IPs and paths not visible in the free view. Date is the chart update date.

[S8] The Hacker News: WordPress RCE flaw draws nearly 63,000 attacks (article on the staging-path flaw)
Published 2026-10-30 · **B2** Usually reliable, probably true
Relays Wordfence attack data and exploitation conditions. Title paraphrased from the URL.

[S9] Patchstack: WordPress 7.1.4 Security Release
Published 2026-10-28 · **B2** Usually reliable, probably true
Best technical root-cause and fix analysis. Date from S15.

[S10] ThreatDefence: WordPress CVE-2026-119977: Hunting the 7.1.4 Upgrade RCE
Published · **C2** Fairly reliable, probably true
Secondary hunting guide; content current to 2026-11-04. Queries and remediation steps are the author's own. Publication date not captured.

[S11] Qualys ThreatPROTECT: CISA Warns of WordPress Vulnerability Exploited in the Wild (CVE-2026-119977)
Published 2026-11-04 · **B2** Usually reliable, probably true
Branch table agrees with S6; provides QID 735969.

[S12] Trend Micro: SECURITY ALERT: WordPress Core unauthenticated RCE (CVE-2026-119977)
Published · **B2** Usually reliable, probably true
Detection rule identifiers. Lists no indicators and mentions only 7.1.4 as fixed. Publication date not captured.

[S13] CISA: BOD 26-04 implementation guidance: Prioritizing Security Updates Based on Risk
Published · **A1** Completely reliable, confirmed by other sources
Primary guidance. Forensic triage order and timing. Publication date not captured.

[S14] GBHackers: WordPress 7.1.4 Fixes 22 Security Vulnerabilities, Including RCE Flaw Under Active Attack
Published 2026-10-30 · **C2** Fairly reliable, probably true
Relays Wordfence rule timing and request counts.

[S15] Rescana: WordPress Core 7.1.4 upgrade staging race RCE
Published · **C2** Fairly reliable, probably true
Careful secondary summary with a UTC-convertible timeline, checked 2026-10-31, before the KEV listing, so its KEV statement is out of date. Publication date not captured.

[S16] SOC Prime: CVE-2026-119977: WordPress Core RCE Exploited
Published · **C3** Fairly reliable, possibly true
Secondary. States no stable IOCs and no public PoC in the sources it reviewed. Publication date not captured.

[S17] IONOS: WordPress 7.1.4 customer help notice
Published · **B3** Usually reliable, possibly true
Hosting provider's statement about its own protections; not independently verified. Title is descriptive. Publication date not captured.

[S18] Pantheon: WordPress 7.1.4 release note
Published 2026-10-28 · **B3** Usually reliable, possibly true
Hosting provider's statement. Does not name which flaws its mitigations cover.

[S19] FIRST: EPSS API result for CVE-2026-119977
Published 2026-11-04 · **A2** Completely reliable, probably true
Model output, not an observation. Score 0.0102, percentile 0.63514.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-10-28	WordPress 7.1.4 released with the upgrade-window fix; backports to older branches follow.	[S2] [S6]
2026-10-28	Wordfence deploys its firewall rule to paid customers at 20:30 UTC and logs the first matching request about nine minutes later.	[S14] [S15]
2026-10-29	WordPress publishes GHSA-4w3m-c66w-69mg, rating the flaw Low. Wordfence publishes its analysis, reporting over 18,500 requests in the first 21 hours.	[S6] [S14] [S15]
2026-10-30	Press relays Wordfence's count of 62,969 attacks blocked in 24 hours. Previdian records three attempts from one UK-geolocated address.	[S7] [S8]
2026-10-31	CVE-2026-119977 is published by Wordfence as CNA, scored CVSS 8.1.	[S3]
2026-11-03	CISA adds the CVE to KEV, citing evidence of active exploitation, with ransomware use marked Unknown.	[S4] [S5]
2026-11-04	Reports put recent blocked attempts at about 12,300 to 12,600 per 24 hours. EPSS stands at 0.0102.	[S1] [S10] [S19]
2026-11-06	Federal civilian agency remediation due date.	[S4]
2026-11-27	Scheduled release of the Wordfence firewall rule to free-tier users.	[S10] [S14]
2026-12-08	Planned WordPress 7.2 release, the next broad update event.	[S2]

Relevance to Indianapolis, Indiana & managed clients

We found no Indiana-specific reporting, state advisory or known victim tied to this flaw, so the following is an assessment of likely exposure. WordPress is common among the Indiana organizations least likely to have dedicated security staff: municipal and county sites, school districts and university departments, clinics and community health groups, manufacturers' marketing sites, and small businesses. Most public sites of this kind do

not hold regulated data directly, but a compromised site can leak database credentials, host malicious content, or abuse trust in a government or healthcare brand. Sites that share hosting or reused credentials can extend the harm. Hospitals and local governments should check for forgotten microsites and sites run by outside agencies. The federal due date does not bind state or local bodies, but CISA encourages all organizations to prioritize KEV items, and 2026-11-06 is a sensible target. For managed IT service clients, the main risks are unmanaged sites outside the normal patch process and multi-tenant servers where one compromised site reaches others. Providers should apply the web server block across the fleet first, since it is one change that covers many sites, then patch, then review logs around each site's update time. Client communication should make clear that sites updated since 2026-10-28 need a log review even though they now show a fixed version, and that a review with no findings is limited by how long logs were retained.

Intelligence gaps

- Whether any exploitation attempt has succeeded. CISA has not published its evidence and no vendor has documented a confirmed compromise.
- Attacker identity and motive. No actor is named, and ransomware use is listed as Unknown.
- Attacker IPs, user agents and payloads. Previdian holds these behind paid tiers and Wordfence has not published them. A subscription to Previdian's telemetry or Wordfence's threat data may fill this gap.
- Whether exploitation occurred before the 2026-10-28 release. The sink is old, but no source reports earlier attacks.
- How many sites are exposed. No source counts sites meeting all conditions, such as web and PHP access to the staging tree, and how often normal updates use the full package is not quantified.
- The exact pre-fix staging folder names, which are not published in the sources read.
- Whether an attacker can force or reliably predict an update on a target site. Sources describe waiting for updates, not triggering them.
- NVD's analysis status. The NVD page could not be read; secondary sources disagree or are dated on whether analysis has finished.
- Whether 4.6 and earlier are exploitable. They sit outside the CVE range, but Patchstack dates the sink to version 2.8.
- Watch for: Wordfence updates, a WordPress advisory update adding the CVE, published PoC code, CISA follow-up, and any change in the KEV ransomware field.

Other notes

- Source limitation: Wordfence's blog post and vulnerability records returned empty content to our fetch tool, and NVD also could not be read. All Wordfence figures here are second-hand through S1, S8, S10, S14 and S15. Analysts should read the originals directly: https://www.wordfence.com/blog/2026/10/wordpress-7-1-4-security-release-rce/ and the advisory linked in the KEV notes.
- The attack counts are not on one scale and should not be added together. Over 18,500 refers to requests to staged setup-config.php paths in the first 21 hours [S1] [S14]. 62,969 refers to blocks in a 24-hour period before 2026-10-30 [S8]; S15 could not find this number in Wordfence's post, and it may come from the vulnerability record, which is our inference. 12,632 [S1] [S11] and 12,289 [S10] are 24-hour blocked counts taken at different moments. SOC Prime attributes a figure of nearly 59,000 to GBHackers [S16], but we did

not find it in the GBHackers article as read [S14]. Wordfence itself notes that not every request used the exact vulnerable path [S8].

- Previdian's first activity timestamp (2026-10-30, 05:46 UTC) comes before the CVE was reserved later that day [S3] [S7]. This is not necessarily an error, since Wordfence saw attempts from 2026-10-28, before any CVE existed, but it is a single-sensor data point.
- CISA's SSVC entry in the CVE record marks Automatable as 'no' while polling is clearly automated [S3] [S8] [S16]. We read this as meaning that the full kill chain cannot be reliably automated because success depends on the victim's update timing, not that attempts are manual. This is our interpretation.
- Reports differ on the size of the release: 22 vulnerabilities [S14], 13 security issues [S18]. Trend Micro lists only 7.1.4 as fixed [S12], but the GHSA backports are authoritative [S6].
- Firewall claims differ in emphasis. Patchstack says a PHP firewall cannot block the request [S9], while Wordfence's guidance as relayed by others is that the firewall must load before WordPress using Extended Protection [S10] [S15]. Web server or edge blocking avoids the question.
- Search results also surface WordPress 'wp2shell' scanners and IOC lists on GitHub. These relate to different CVEs, so their indicators should not be used for this flaw. S10 and S16 report no public PoC for CVE-2026-119977 in the sources they reviewed; we did not look for exploit code.
- The briefing refers to an earlier intel report on this topic, CTI-20261102-03 dated 2026-11-02. It was not reviewed for this report. The main changes since that date are the KEV listing and the federal due date.
- CERT-FR advisory CERTFR-2026-AVI-1420 is reported to cover versions before 7.1.4 [S15]. We did not open it.

CTI-20261104-04 v1.0 · Generated 2026-11-04 10:38 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.